



## Elasticsearch Security and Health Assessment

Context-aware evaluation of Elasticsearch vulnerabilities, runtime consistency, configuration, health, and resilience. No exploit or state-changing operation was performed.

Generated 2026-08-28 10:49:59 UTC | scanner v0.1.0 | profile standard | deep true

|                        |                                              |
|------------------------|----------------------------------------------|
| <b>Cluster</b>         | docker-cluster                               |
| <b>Elasticsearch</b>   | 8.19.20                                      |
| <b>Target</b>          | http://127.0.0.1:19200/                      |
| <b>Overall health</b>  | High Risk   score 25 / 100                   |
| <b>Topology</b>        | 1 nodes, 3 indices, 3 shards, 59.25 KiB data |
| <b>Severity counts</b> | critical 2, high 2, medium 1, low 0, info 0  |

## Top risks

**CRITICAL** Elasticsearch HTTP traffic is not protected by TLS (http)

Network observers can read or modify Elasticsearch traffic; credentials sent over HTTP are exposed.

**CRITICAL** Credentials were sent over HTTP because plaintext authentication was explicitly allowed (http\_plaintext\_auth)

The operator override transmitted secrets on an unencrypted Elasticsearch HTTP connection.

**HIGH** No snapshot repository is configured (docker-cluster)

The cluster has no visible Elasticsearch snapshot backup path.

**HIGH** Disk-based shard allocation thresholds are disabled (cluster.routing.allocation.disk.threshold\_enabled)

Elasticsearch can continue allocating shards to critically full nodes.

**MEDIUM** Single-node cluster has no node-level redundancy (docker-cluster)

A node or host failure makes the entire cluster unavailable.

## Top resource consumers

### Node by disk

| Resource     | Usage  |
|--------------|--------|
| 1c7748d13658 | 69.16% |

### Node by JVM heap

| Resource     | Usage  |
|--------------|--------|
| 1c7748d13658 | 59.00% |

### Node by shards

| Resource     | Usage       |
|--------------|-------------|
| 1c7748d13658 | 3.00 shards |

## Detailed findings

### 1. ES-SEC-001 CRITICAL Elasticsearch HTTP traffic is not protected by TLS

| Field              | Value                                                                                                                        |
|--------------------|------------------------------------------------------------------------------------------------------------------------------|
| Category           | Security                                                                                                                     |
| Resource           | transport/http                                                                                                               |
| Confidence         | HIGH                                                                                                                         |
| Threshold          | HTTPS                                                                                                                        |
| Operational impact | Network observers can read or modify Elasticsearch traffic; credentials sent over HTTP are exposed.                          |
| Recommended action | Enable and verify TLS on the Elasticsearch HTTP interface or its trusted reverse proxy. Avoid sending credentials over HTTP. |
| Evidence           | allow_plaintext_auth=true, credentials_used=[REDACTED], https_enabled=false                                                  |

**2. ES-SEC-001 CRITICAL****Credentials were sent over HTTP because plaintext authentication was explicitly allowed**

| Field              | Value                                                                                                |
|--------------------|------------------------------------------------------------------------------------------------------|
| Category           | Security                                                                                             |
| Resource           | transport/http_plaintext_auth                                                                        |
| Confidence         | HIGH                                                                                                 |
| Threshold          | HTTPS or no credentials                                                                              |
| Operational impact | The operator override transmitted secrets on an unencrypted Elasticsearch HTTP connection.           |
| Recommended action | Use HTTPS and keep --allow-plaintext-auth disabled except for explicitly authorized, isolated tests. |
| Evidence           | allow_plaintext_auth=true, credentials_used=[REDACTED], https_enabled=false                          |

**3. ES-BACKUP-001 HIGH****No snapshot repository is configured**

| Field              | Value                                                                                                                                |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Category           | Snapshot                                                                                                                             |
| Resource           | cluster/docker-cluster                                                                                                               |
| Confidence         | HIGH                                                                                                                                 |
| Threshold          | at least one operational backup repository                                                                                           |
| Operational impact | The cluster has no visible Elasticsearch snapshot backup path.                                                                       |
| Recommended action | Configure and monitor a snapshot repository through an authorized workflow. The health check does not verify or modify repositories. |
| Evidence           | repositories=0                                                                                                                       |

**4. ES-CONFIG-001 HIGH****Disk-based shard allocation thresholds are disabled**

| Field              | Value                                                                                              |
|--------------------|----------------------------------------------------------------------------------------------------|
| Category           | Configuration                                                                                      |
| Resource           | cluster_setting/cluster.routing.allocation.disk.threshold_enabled                                  |
| Confidence         | HIGH                                                                                               |
| Threshold          | true                                                                                               |
| Operational impact | Elasticsearch can continue allocating shards to critically full nodes.                             |
| Recommended action | Re-enable disk thresholds through an authorized change after understanding why they were disabled. |
| Evidence           | effective_value=false                                                                              |

**5. ES-AVAIL-001 MEDIUM****Single-node cluster has no node-level redundancy**

| Field      | Value                                        |
|------------|----------------------------------------------|
| Category   | Availability                                 |
| Resource   | cluster/docker-cluster                       |
| Confidence | HIGH                                         |
| Threshold  | more than one node for node-level redundancy |

| Field              | Value                                                                                                                                                   |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Operational impact | A node or host failure makes the entire cluster unavailable.                                                                                            |
| Recommended action | For production workloads, deploy additional role-appropriate nodes across independent failure domains. A single node may be intentional in development. |
| Evidence           | number_of_nodes=1, profile=standard                                                                                                                     |

## Prioritized action plan

### P0 Immediate

- Enable and verify TLS on the Elasticsearch HTTP interface or its trusted reverse proxy. Avoid sending credentials over HTTP.
- Use HTTPS and keep --allow-plaintext-auth disabled except for explicitly authorized, isolated tests.

### P1 Urgent

- Configure and monitor a snapshot repository through an authorized workflow. The health check does not verify or modify repositories.
- Re-enable disk thresholds through an authorized change after understanding why they were disabled.

### P2 Planned

- For production workloads, deploy additional role-appropriate nodes across independent failure domains. A single node may be intentional in development.

### P3 Optimization

None.

## Assessment coverage and scanner telemetry

|              |                                                                      |
|--------------|----------------------------------------------------------------------|
| Checks       | 35 executed / 39 available   passed 31 skipped 4 failed 0 findings 5 |
| API requests | 16   retried 0   failed 1                                            |
| Downloaded   | 87.66 KiB                                                            |
| Duration     | 761 ms                                                               |

| Collector             | Cost   | Status  | HTTP | Reason               |
|-----------------------|--------|---------|------|----------------------|
| allocation_explain    | MEDIUM | skipped | -    | no_unassigned_shards |
| authenticate          | LOW    | success | 200  | -                    |
| cluster_health        | LOW    | success | 200  | -                    |
| cluster_settings      | LOW    | success | 200  | -                    |
| cluster_stats         | LOW    | success | 200  | -                    |
| data_streams          | MEDIUM | success | 200  | -                    |
| ilm                   | HIGH   | skipped | 405  | api_unavailable      |
| index_settings        | MEDIUM | success | 200  | -                    |
| indices               | MEDIUM | success | 200  | -                    |
| nodes_info            | LOW    | success | 200  | -                    |
| nodes_settings        | MEDIUM | success | 200  | -                    |
| nodes_stats           | MEDIUM | success | 200  | -                    |
| pending_tasks         | LOW    | success | 200  | -                    |
| root                  | LOW    | success | 200  | -                    |
| shards                | MEDIUM | success | 200  | -                    |
| snapshot_repositories | MEDIUM | success | 200  | -                    |
| tasks                 | HIGH   | success | 200  | -                    |

## Methodology

---

This assessment combines cluster health, node resources, JVM, disk, shard and index architecture, workload pressure, lifecycle, backup, security, capacity, availability, and reliability evidence. The Elasticsearch cluster-health color is not used as the sole health decision.

Developer Cuma Kurt | <https://www.linkedin.com/in/cuma-kurt-34414917/> | <https://github.com/cumakurt>